

インターネット公開型情報システム 開発・運用標準

2021年3月

JR 東日本コンサルタンツ株式会社

目次

第1章	総則	
1	目的	2
2	適用範囲	2
3	用語の意義	2
第2章	管理体制	
1	セキュリティ管理体制	5
2	情報セキュリティ上の脅威の把握と対策の実施	5
3	情報セキュリティ教育の実施	5
4	個人情報の取扱い	5
5	機密保持契約の締結	6
6	保守・運用作業の手順	6
7	緊急連絡体制の整備	6
8	コンピュータウイルス検出時の対応方法の整備	6
9	データ記録メディアの取扱い	6
10	システムの設置環境	6
11	保守・運用に用いるアカウントの管理	7
12	特権アカウントのパスワード管理	7
13	ログの取得と保存期間	8
14	セキュリティ診断試験の実施と脆弱性の改善	9
15	利用者別のアクセス制御	9
第3章	ネットワーク	
1	ファイアウォールの設置とネットワークの領域構成	10
2	サーバに対するアクセス制御	10
3	不正侵入通信の防止措置	10
第4章	サーバ	
1	個人情報を取り扱う場合のデータ格納方法	11
2	サーバに対するウイルス対策	11
3	サーバに対する脆弱性対策	11
第5章	保守端末	
1	保守用端末と一般業務用端末機能の分離	12
2	保守用端末の制限措置	12
3	導入ソフトウェアの管理	12
4	保守用端末のウイルス対策	12
5	保守用端末に対する脆弱性対策	13
6	コンテンツ更新時のセキュリティチェック	13
7	保守用端末の移動の禁止	13
第6章	その他	
1	自社設備以外を利用する場合の取扱い	13
2	データの消去	13

インターネット公開型情報システム開発・運用標準

(2021年3月1日 社達第18号)

情報システムセキュリティ取扱規程第9条第1項第2号の定めに基づきインターネット公開型情報システム開発・運用標準を次のように定める。

目次

- 第1章 総則 (1-3)
- 第2章 管理体制 (1-15)
- 第3章 ネットワーク (1-3)
- 第4章 サーバ (1-3)
- 第5章 保守端末 (1-7)
- 第6章 その他 (1-2)
- 附則

第1章 総則

1 目的

この標準は、JR 東日本コンサルタンツ株式会社（以下「会社」という。）が不特定多数のインターネット利用者に対して公開する情報システムを開発または運用する場合に、当該情報システムの利用者に対するセキュリティ上の脅威を排除し、個人情報等の漏えい・流出を防止するために最低限確保すべき情報セキュリティレベルを定め、当該情報システムの利用者が安全に安心して利用できる環境を構築し維持することを目的とする。

2 適用範囲

2.1 適用範囲

この標準は、会社が開発・運用経費の全部または一部を負担し、不特定多数のインターネット利用者に対して公開するインターネット公開型情報システムまたはサービスに対して適用するものとする。

2.2 標準に定めていない事項

この標準に定めていない事項については、別に定めるものによる。

(注) 別に定めるものの主なものは、次のとおりである。

「情報システムセキュリティ取扱規程」(2021年3月)

「JRC 情報セキュリティ取扱標準」(2021年3月)

3 用語の意義

この標準における用語の意義は、次の各号に掲げるとおりとする。

(1) 「OS」とは、キーボード入力や画面出力といった入出力機能や、ハードディスク、メモリ

の管理等、多くのアプリケーションソフトから共通して利用される基本機能を提供する、コンピュータ全体を管理するための基本ソフト（Operating System）をいう。

- (2) 「アカウント」とは、コンピュータやネットワーク上の機器等を利用する権利のことをいい、利用者識別情報と同じ意味で使われる。なお、アカウントを用いてコンピュータを操作する権利を取得することを「ログイン（ログオン）」という。
- (3) 「アクセス」とは、ネットワークを通じて一定の手続きを経てコンピュータ間でデータの転送が可能となる状態をいう。
- (4) 「アプリケーション」とは、OS が提供する基本機能を利用して、ある目的のために造りこまれた専用のソフトウェアをいう。
- (5) 「ウェブブラウザ」とは、インターネット上のホームページ等を閲覧するためのソフトウェア（インターネットエクスプローラー等）をいう。
- (6) 「インターネット公開」とは、インターネット利用者に対して何らかの機能・サービスを提供することを目的に構成されたコンピュータ機器が、インターネット利用者から利用可能な状態にあることをいう。
- (7) 「ウェブシステム」とは、インターネット上のサービスの一つである WWW (World Wide Web) 技術を用いて提供される一連の情報の集合体を取り扱うシステムをいう。
- (8) 「ウェブサーバ」とは、ウェブシステムにおいて、インターネット利用者が利用するウェブブラウザからの要求に応じて、情報を発信する役割を果たすサーバをいう。
- (9) 「ブログ」とは、日記のように更新、書き込みが容易で、画像や音声もアップ可能なホームページをいう。
- (10) 「コンテンツ」とは、インターネット上で閲覧することが可能な文字、映像、音楽等のデジタル化されたデータをいう。
- (11) 「ウェブアプリケーション」とは、ウェブブラウザ（インターネットエクスプローラー等）を通じて利用できるウェブサーバ側で動作するアプリケーションプログラムのことをいう。
- (12) 「コンテンツフィルタ」とは、コンテンツの内容によって、使用者に閲覧させるか遮断させるかを判断する仕組みをいう。
- (13) 「脆弱性修正プログラム（セキュリティパッチ）」とは、ソフトウェアに保安上の弱点が発覚した時に、その原因となっているファイルを、問題のないファイルに置き換えるプログラムをいう。
- (14) 「サイバー攻撃」とは、インターネット経由で他のコンピュータに不正アクセスを行い、相手方のシステムに被害・損害を与える行動をいう。
- (15) 「ファイアウォール」とは、インターネットからウェブシステム上のサーバ等に対するサイバー攻撃等を遮断する機能を持つ通信装置をいう。
- (16) 「侵入検知装置（IDS）」とは、通信回線を監視し、ネットワークへの侵入を検知して、管理者に通報するシステムをいう。
- (17) 「侵入防御装置（IPS）」とは、侵入検知装置（IDS）の機能に加え、侵入を検知時に接続の遮断などの防御を行う機能を持つシステムをいう。
- (18) 「ウェブアプリケーションファイアウォール（WAF）」とは、ウェブアプリケーションへの外

部からの攻撃・侵入を検知・防止するシステムをいう。

- (19)「電子証明書」とは、利用者あるいは端末自身の正当性を証明するため、認証局が発行した電子署名用の鍵データが真正であることを証明するためのデータをいう。
- (20)「コンテンツ管理システム (CMS)」とは、ウェブシステムのコンテンツ編集や、情報管理 (コンテンツのバージョン管理など) を行うためのシステムである。なお、この規程では、ウェブシステムのコンテンツ保守、情報システム環境の構築や変更、コンテンツ保守作業に使用する場合を想定しているため、一般ユーザーの使用 (ブログ等での使用) は対象としない。
- (21)「特権アカウント」とは、システムの保守・運用に必要な限定された操作権限をもつアカウントをいう。
- (22)「保守用端末」とは、コンピュータ機器に対して特権でアクセスし、変更・修正の作業を行うために用いるソフトウェア保守端末のことをいう。「システム保守端末」とはハードウェアや OS・アプリケーションソフトウェアのメンテナンスを行うものをいい、「コンテンツ保守端末」とはウェブコンテンツのメンテナンスを行うものをいう (ウェブシステムのコンテンツ保守を行うためにコンテンツ管理システム [CMS] を利用する場合を含む)。
- (23)「情報セキュリティ主管管理者」とは、情報システムセキュリティ取扱規程第 6 条に定める情報システムごとに設置される管理者をいい、その業務として、所管する情報システム資源の保護及び情報セキュリティ確保の活動に関する管理・指導を行う。
- (24)「情報セキュリティ主管管理者 (補助)」とは、情報システムセキュリティ取扱規程第 6 条に定める管理すべき情報システムを所管している部署長をいい、その業務として、部署の所管する情報システム資源の保護及び情報セキュリティ確保の活動に関する管理・指導を行う。
- (25)「ロックアウト」とは一定回数以上ログイン (ログオン) に失敗した場合に、アカウントを一時的に無効することをいう。
- (26)「多要素認証」とは以下の 3 種類のうち 2 種類以上を利用する認証のことをいう。
- ア 記憶情報
パスワードやパスフレーズなどユーザーが記憶している情報
 - イ 所有情報
トークンデバイス、IC カード、スマートフォンへのワンタイムパスワード通知 (SMS、MMS、アプリ)、電話 (音声)、電子証明書などが所持しているもの
 - ウ 生体情報
指紋、虹彩、声紋、静脈パターンなどユーザー自身を示すもの
- (27)「ホワイトリスト方式」とは、安全が確認されている対象のリストを作り、リストに無い項目は排除する方式をいう。
- (28)「ワンタイムパスワード」とは、システムの発行される一度限りかつ一定時間のみ使用可能なパスワードのことをいう。
- (29)「本部等」とは、各統括本部、各本部、本部に属さない部署及び支店をいう。
- (30)「本部長等」とは、各本部の本部長 (統括本部に属する本部においては統括本部長)、本部に属さない部署の指定役員及び支店長をいう。

第2章 管理体制

1 セキュリティ管理体制

1.1 情報セキュリティ主管管理者等の配置

情報セキュリティ統括管理者は、インターネット公開型情報システムの開発・運用を行う場合、管理すべき情報システムを所管している本部等に情報セキュリティ主管管理者を配置するものとする。

情報セキュリティ統括管理者は、管理すべき情報システムを所管している本部長等をもって情報セキュリティ主管管理者にあてる。

情報セキュリティ主管管理者は、管理すべき情報システムを所管している部署の部署長を情報システム主管管理者（補助）に選任する。

1.2 情報セキュリティ主管管理者等の責務

情報セキュリティ主管管理者は、本部等の所管する情報システムの資源の保護及び情報セキュリティ確保の活動に関する管理・指導を行うものとする。

情報セキュリティ主管管理者は、情報セキュリティ主管管理者（補助）の指揮・監督を行う。

情報セキュリティ主管管理者（補助）は、部署の所管する情報システムの資源の保護及び情報セキュリティ確保の活動に関する管理・指導を行うものとする。

2 情報セキュリティ上の脅威の把握と対策の実施

情報セキュリティ主管管理者は、OS やアプリケーションの脆弱性情報等セキュリティの確保に関する情報を収集するとともに、脆弱性対策を講じるものとする。

3 情報セキュリティ教育の実施

3.1 情報セキュリティ教育の実施

情報セキュリティ主管管理者は、保守・運用に従事する社員に対して、年1回以上、当該システムのセキュリティを確保するために必要な教育・措置について実施状況を確認するものとする。

3.2 委託先における情報セキュリティ教育の実施

情報セキュリティ主管管理者は、保守・運用業務を委託している場合、委託先における前項に定める教育・措置の実施状況を確認するものとする。

4 個人情報の取扱い

情報セキュリティ主管管理者は、インターネット公開型情報システムのうちウェブシステムにおいて個人情報を取り扱う場合は、次の事項を実施するものとする。

- (1) 個人情報がインターネットを経由して送受信される場合は、その通信を暗号化すること。
- (2) 個人情報を格納するデータベースは、そのデータを暗号化することを基本とする。
- (3) 上記2項目における暗号化は、公的機関により規格化された方式であること。

5 機密保持契約の締結

情報セキュリティ主管管理者は、インターネット公開型情報システムの保守・運用およびウェブコンテンツ製作等を委託する場合は、機密保持契約を締結するか、他の契約条文中に機密保持に関する条項を設けるものとする。また、委託先が再委託を行う場合であっても、同様の機密保持を行うものとする。

6 保守・運用作業の手順

情報セキュリティ主管管理者は、インターネット公開型情報システムを構成するコンピュータ機器、ネットワーク機器および保守・運用作業について、責任を明確にした手順書を定め、その定めに従って作業を実施するものとする。

7 緊急連絡体制の整備

7.1 緊急連絡体制の整備

情報セキュリティ主管管理者は、インターネット公開型情報システムを構成するコンピュータ機器、ネットワーク機器および保守端末の情報セキュリティに問題が発生した場合における連絡体制を整備するものとする。

7.2 委託先の緊急連絡体制の整備

情報セキュリティ主管管理者は、保守・運用業務を委託している場合、委託先も含めた連絡体制を整備するものとする。

8 コンピュータウイルス検出時の対応方法の整備

情報セキュリティ主管管理者は、インターネット公開型情報システムを構成するコンピュータ機器および保守端末において、コンピュータウイルスを検出した時の取扱い、連絡体制、駆除の方法、駆除が不可能な場合の現状保全に関する対応方法を定めるものとする。

9 データ記録メディアの取扱い

9.1 データ記録メディアの取扱い

情報セキュリティ主管管理者は、インターネット公開型情報システムを構成するコンピュータ機器、ネットワーク機器および保守端末で使用する全てのデータ記録メディアは、会社が許可したもののみとし、利用ルールを定めるものとする。

9.2 個人情報を扱ったデータ記録メディアの取扱い

データ記録メディアを使用して個人情報を搬送する場合は、当該データを暗号化するものとする。

10 システムの設置環境

10.1 システムの設置環境

情報セキュリティ主管管理者は、インターネット公開型情報システムを構成するコンピュータ機器およびネットワーク機器等を、許可された者以外が立ち入ることができない専用区画に設置することを基本とする。

10.2 専用の区画の確保が困難な場合のシステムの設置環境

専用の区画の確保が困難な場合は、施錠可能なラック等へ機器類を搭載し、許可された者以外が手を触れられないよう措置するものとする。

10.3 記録簿の管理

専用の区画を設けた場合は「入退出記録簿」を、施錠可能なラック等を設けた場合は「鍵貸出記録簿」を備え、専用の区画またはラック等の管理責任者による厳正な管理のもと、最低3ヶ月以上の記録を保管するものとする。

11 保守・運用に用いるアカウントの管理

情報セキュリティ主管管理者は、インターネット公開型情報システムを構成するコンピュータ機器および保守端末等において、当該システムの保守・運用の際に用いるアカウントを、次により管理するものとする。

- (1) 通常の保守・運用に際しては、当該システムの保守・運用に必要な権限に特化した特権アカウントを用いて運用すること。
- (2) 特権アカウントは保守・運用係員個人に付与するものとし、複数の保守・運用係員が共用しないことを基本とすること。
- (3) 特権アカウントおよび標準管理者アカウントは、保守・運用に従事しない者に対して開示しないこと。
- (4) やむを得ず共用の特権アカウントまたは標準管理者アカウントを使用する場合は、利用の都度、使用者が目的・使用者・利用時間・作業内容等を「特権アカウント利用記録簿」等に記録し、最低1年間以上の記録を保管すること。

12 特権アカウントのパスワード管理

12.1 特権アカウントのパスワード管理

情報セキュリティ主管管理者は、インターネット公開型情報システムを構成するコンピュータ機器および保守端末等において、保守・運用に用いる特権アカウントのパスワードを、次により取り扱うものとする。

- (1) パスワード文字列は7文字以上とし、英文字と数字を含むこと。
- (2) パスワードに使用する文字列は、特権アカウント（利用者識別情報）の文字列と同一のものや使用するキーボード配列の一部と同一であるなど、他人から類推され易い文字列を含めないこと。
- (3) パスワードは概ね90日以内に変更し、過去2回の変更時に使用していたものを再利用しないこと。
- (4) アカウントをロックアウトする機能を有する場合は、該当機能を有効化すること。

12.2 特権アカウントの定期変更不要の場合

個人別に付与した特権アカウント（利用者識別情報）を利用する場合は、次のいずれかの取り扱い方法を実施することにより前項（3）のパスワードの定期変更を不要とすることができる。なお、特権アカウント（利用者識別情報）を他の利用者に引き継ぐ場合は、パスワードを

変更した上で利用すること。

- (1) 多要素認証を実施する場合。
- (2) パスワード文字列を 10 文字以上とし、英大小文字と数字、記号を含み、10 回以内のロックアウト回数を設けた場合。
- (3) パスワード文字列を 11 文字以上とし、英大小文字と数字を含み、10 回以内のロックアウト回数を設けた場合。

13 ログの取得と保存期間

13.1 ログの取得と保存期間

情報セキュリティ主管管理者は、インターネット公開型情報システムを構成するコンピュータ機器、ネットワーク機器について、動作の証跡として下表に示すログを取得し、当該情報システムが取り扱う情報の種別に応じて、表中に示す期間保管するものとする。なお、クラウド事業者から下表に示すログが提供されない場合は、「セキュリティ事故等の発生時に、定める期間のログを事業者側で調査分析し、情報が提供されること」を事業者を確認するものとする。

取得対象 ログ 取扱 情報種別	ウェブサーバ	ファイアウォール IDS/IPS・WAF	個人情報へのアクセ スログ* ³
	アクセスログ* ¹	ドロップログ* ²	
お客さまの個人情報	1 年間以上		
社員の個人情報	3 ヶ月間以上		
個人情報なし	1 ヶ月以上		

※1 ウェブサーバへのアクセスログ (HTTP アクセスログ)

※2 これらの機器または機能で検出された通信を拒否したことがわかるログ

※3 個人情報データへのアクセス状況が確認できるオブジェクトアクセスログ

13.2 特権アカウントの動作の証跡

情報セキュリティ主管管理者は特権アカウントの操作に関する動作の証跡（以下操作証跡という）を記録するものとする。操作証跡として取得すべきものは「使用日時」「使用した特権アカウント名」「操作の実行元のコンピュータ名や IP アドレス」「操作内容（作業内容）」とする。

13.3 特権アカウントの操作証跡の保存期間

特権アカウントの操作証跡の保管期間は、お客さまの個人情報を保有するシステムは 1 年間以上、社員の個人情報を保有するシステムは 3 ヶ月間以上、個人情報を保有しないシステムは 1 ヶ月間以上とする。

13.4 特権アカウントの操作証跡の解析

情報セキュリティ主管管理者は特権アカウントの操作証跡についてクレジットカード情報を保有するシステムについては、1 日に 1 回、インターネット公開型情報システムについては 30 日に 1 回解析を行うことを基本とする。

14 セキュリティ診断試験の実施と脆弱性の改善

14.1 セキュリティ診断試験の実施と脆弱性の改善

情報セキュリティ主管管理者は、インターネット公開型情報システムに対するサイバー攻撃による被害を未然に防止するため、ウェブアプリケーションの新規開発または改修を行なった場合には、その機能を利用者に提供する前に、セキュリティ診断試験を実施することを基本とする。このうち、お客さまの個人情報を取り扱うシステムについては、毎年定期的にセキュリティ診断試験を実施するものとする。

14.2 セキュリティ診断試験によって脆弱性が発見された場合

情報セキュリティ主管管理者は、前項で実施したセキュリティ診断試験によって脆弱性が発見された場合には、脆弱性を改善したのちに、その機能を提供することを基本とする。

15 利用者別のアクセス制御

情報セキュリティ主管管理者は、インターネット公開型情報システムにおいて、利用者別に利用者識別情報（一般のお客さま用等、実態として管理できないものは除く）を付与し、当該利用者のアクセス可能な範囲を制御する場合は、次により管理するものとする。

- (1) 利用者識別情報に与える、アクセス可能な範囲を限定すること。
- (2) 利用者識別情報は、個人別に付与するものとし、そのパスワードの取扱いは、第 16 条に定める取扱いと同等の取扱いを基本とすること。
- (3) 利用者識別情報を複数の利用者で共用する場合のパスワードの取扱いは、第 16 条に定める取扱いと同等の取扱いを基本とすること。
- (4) 不要な利用者識別情報の有無について、半年に 1 回以上確認を行い、不要なものは速やかに削除することを基本とすること。

第3章 ネットワーク

1 ファイアウォールの設置とネットワークの領域構成

情報セキュリティ主管管理者は、インターネット公開型情報システムを構成するネットワークについて、ファイアウォールを設置するものとし、公開すべき情報の通信のみ許可するよう、次のような領域を構成し管理するものとする。

- (1) 限定公開領域 (DMZ)：公開用サーバを設置する領域とし、当該サーバが公開するサービスの通信に対してのみ、インターネット側からのアクセスを許可するようにファイアウォールで設定された領域。
- (2) 内部ネットワーク領域：サーバと連携するデータベースサーバ等を設置する領域とし、限定公開領域 (DMZ) に設置されたサーバとの通信を許可し、インターネット側からのアクセスを禁止するようにファイアウォールで設定された領域。

2 サーバに対するアクセス制御

2.1 サーバに対するアクセス制御

情報セキュリティ主管管理者は、情報システムに接続可能な保守用端末を正規の保守用端末に限定するため、次の措置を講じるものとする。

- (1) 正規発信元 IP アドレス以外からの通信を禁止すること。
- (2) コンテンツ管理システム (CMS) を用いてコンテンツ保守作業を行う必要がある場合は、当該 CMS サーバへのアクセスは正規発信元 IP アドレス以外からの通信を禁止すること。

2.2 保守用端末を限定できない場合の対策

前項により接続可能な保守用端末を限定できない場合は、多要素認証等による不正アクセス防止の対策を講じること。

3 不正侵入通信の防止措置

3.1 不正侵入通信の防止措置

情報セキュリティ主管管理者は、個人情報を取り扱うインターネット公開型情報システムのうち、お客さまの個人情報を取り扱うシステムについては、ファイアウォールを通過して操作される不正な通信を検出または防止するため、侵入検知装置 (IDS) もしくは侵入防御装置 (IPS) を導入するか、導入するソフトウェア機能として当該機能をサーバ上で実現するものとする。

3.2 不正侵入通信を検出した場合

前項により不正侵入を検出した場合には、遅滞なく情報セキュリティ管理者に情報が伝達されるようにするものとする。

第4章 サーバ

1 個人情報を取り扱う場合のデータ格納方法

インターネット公開型情報システムのうち、ウェブシステムに個人情報を保持し蓄積する場合は、第20条第2号に定める内部ネットワーク領域に設置するデータベースサーバ等に格納し、限定公開領域（DMZ）に設置されたサーバ上に格納しないこととする。

2 サーバに対するウイルス対策

2.1 サーバに対するウイルス対策

情報セキュリティ主管管理者は、インターネット公開型情報システムを構成するサーバ機器について、採用するOS種別にかかわらず以下によるウイルス対策を実施すること。

- （1）ウイルス対策ソフトを導入し、ウイルス検出用のパターンファイルおよびウイルス検出エンジンは、最新の状態を保持すること。
- （2）ウイルス対策ソフトを導入した場合、即時検出機能（リアルタイムスキャン）を有効化するとともに、週1回以上定期的に全検索（フルスキャン）を実施することを基本とする。但し、即時検出機能を利用できないソフトの場合は、少なくとも週1回以上（可能な限り1日1回以上）の全検索を実施することを基本とする。なお、全検索の時間帯は、保守係員が即応できる時間帯を選定すること。
- （3）ウイルス対策ソフトが存在しない等の場合は、ゲートウェイ型ウイルス対策機器または改ざん検知システムを導入し、常時監視すること。

2.2 ウイルス対策ソフトウェアの導入が難しい場合

前項によりウイルス対策ソフトウェアの導入が難しい場合は、動作可能アプリケーションをホワイトリスト方式で限定すること。

3 サーバに対する脆弱性対策

情報セキュリティ主管管理者は、インターネット公開型情報システムを構成しているコンピュータ機器について、当該脆弱性をサイバー攻撃の標的とされないよう、脆弱性修正プログラム（セキュリティパッチ）の適用、または脆弱性を有するサービスの停止等のリスク回避策を講じるものとする。なお、脆弱性修正プログラムは、ウェブサーバにおいては4か月に1回以上、その他のサーバについては年1回以上適用する機会を設けることを基本とする。

第5章 保守端末

1 保守用端末と一般業務用端末機能の分離

1.1 保守用端末と一般業務用端末機能の分離

システム保守用端末は、一般業務用端末とは別の専用端末とすること。

1.2 コンテンツ管理システムを用いる場合

コンテンツ保守用端末は、一般業務用端末とは別の専用端末とすることを基本とすること。

なお、コンテンツ管理システム（CMS）におけるコンテンツの一部のみを保守できるアカウントを用いる場合は、一般業務用端末からコンテンツの保守を行ってもよいものとする。

2 保守用端末の制限措置

情報セキュリティ主管管理者は、保守端末を次のとおり利用制限することとする。

- （1）有害なウェブページを閲覧できないよう、コンテンツフィルタの導入を行う等のインターネット閲覧制限措置を行うこと。
- （2）電子メールシステムの利用によるウイルス感染・情報漏えい防止のため、電子メールシステムの利用停止、もしくは受信メールに対するウイルス対策を実施すること。
- （3）簡易電文送受信ソフト（インスタントメッセージ）等、不特定の相手と通信可能な機能を有するソフトウェアを導入しないこと。
- （4）保守機能を持つ端末を保守権限のない利用者が使用することができないよう、必要な措置を講ずること。

3 導入ソフトウェアの管理

情報セキュリティ主管管理者は、保守用端末に導入するソフトウェアを必要な最小限のものに限定し、保守用端末ごとに次の内容を管理するものとする。また、業務を委託している場合は委託先で同様の管理を行うことを指導するものとする。

- （1）ソフトウェアの品名・名称
- （2）ソフトウェアのバージョン
- （3）ソフトウェアのサポート期限
- （4）ソフトウェアの開発者・製造会社
- （5）ソフトウェアの数量およびライセンス状況

4 保守用端末のウイルス対策

情報セキュリティ主管管理者は、保守用端末について、採用する OS 種別にかかわらず全端末にウイルス対策ソフトを導入し、ウイルス検出パターンファイルおよびウイルス検出エンジンを常時最新の状態に保持するものとする。また、即時検出機能（リアルタイムスキャン）を有効化するとともに、1 週間に 1 回以上定期的に全検索（フルスキャン）を実施すること。なお、全検索の時間帯は、保守係員が即応できる時間帯とすることとする。

5 保守用端末に対する脆弱性対策

情報セキュリティ主管管理者は、保守端末の OS、利用ソフトウェア全般に関して、当該脆弱性をサイバー攻撃の標的とされないよう定期的に脆弱性修正プログラム（セキュリティパッチ）の適用を行うこととする。なお、脆弱性修正プログラムは、2 ヶ月に 1 回以上適用する機会を設けることを基本とする。ただし、ウイルス対策ソフトウェアの導入が難しい場合は、動作可能アプリケーションをホワイトリスト方式で限定すること。

6 コンテンツ更新時のセキュリティチェック

コンテンツを製作する者は、コンテンツの更新等に際しては、第 10 条に定める手順書を厳守するとともに、目視その他の手段により追加するコンテンツの内容を確認することとする。

7 保守用端末の移動の禁止

情報セキュリティ主管管理者は、保守用端末として用いるコンピュータの設置場所をみだりに移動させてはならない。止むを得ない事情により保守端末を移動しなければならない場合は、予めルールを定め厳正に取り扱うこととする。

第 6 章 その他

1 自社設備以外を利用する場合の取扱い

情報セキュリティ主管管理者は、インターネット公開型情報システムのコンピュータ機器、ネットワーク機器等を自社設備以外の借用もしくは委託により運用する場合は、この規程の内容を遵守できることについて、借用もしくは委託先の事業者から書面により証明を受けるものとする。

2 データの消去

情報セキュリティ主管管理者は、情報システムの更新・移設・廃止等の場合に、サーバ、記憶媒体等から情報が漏えいしないように、データを確実に消去し復元不可能な状態にするなどの必要な措置を講じるものとする。

附則

この達は、2021 年 3 月 1 日から施行する。（社達第 18 号）

この達は、2024 年 12 月 1 日から施行する。（社達第 5 号）

